

A. Introduction

1. **Title:** Cyber Security — Configuration Change Management and Vulnerability Assessments
2. **Number:** RRC-CIP-010-1
3. **Purpose:** To prevent and detect unauthorized changes to Bulk Electric System Cyber Systems (BCS) by specifying configuration change management and vulnerability assessment requirements in support of protecting BCS from compromise that could lead to misoperation or instability in the Bulk Electric System (BES).
4. **Applicability:**
 - 4.1. **Functional Entities:** For the purpose of the requirements contained herein, the following list of functional entities will be collectively referred to as “Responsible Entities.”
 - 4.1.1. **Balancing Authority/Load Balancing Authority**
 - 4.1.2. **Generator Operator**
 - 4.1.3. **Generator Owner**
 - 4.1.4. **Transmission Operator**
 - 4.1.5. **Transmission Owner**
 - 4.1.6. **Distribution Provider:** that owns one or more of the following Facilities, systems, and equipment for the protection or restoration of the BES:
 - 4.1.6.1. Each underfrequency load shedding (UFLS) or undervoltage loadshedding (UVLS) system that:
 - 4.1.6.1.1. is part of a Load shedding program that is subject to one or more requirements in a Railbelt Reliability Standard; and
 - 4.1.6.1.2. performs automatic Load shedding under a common control system owned by the Responsible Entity, without human operator initiation, that the loss, compromise, or misuse could have an adverse impact on the reliable operation of the BES.
 - 4.1.6.2. Remedial Action Scheme (RAS) where the RAS is subject to one or more requirements in a Railbelt Reliability Council Standard.
 - 4.1.6.3. Each Protection System (excluding UFLS and UVLS) that applies to Transmission where the Protection System is subject to one or more requirements in a Railbelt Reliability Council Standard.
 - 4.1.6.4. Each Cranking Path and group of Elements meeting the initial switching requirements from a Blackstart Resource up to and including the first interconnection point of the starting station service of the next generation unit(s) to be started.
 - 4.2. **Facilities:** For the purpose of the requirements contained herein, the following Facilities, systems, and equipment owned by each Responsible Entity in 4.1 above are those to which these requirements are applicable. For requirements in this standard where a specific type of Facilities, system, or equipment or subset of Facilities, systems, and equipment are applicable, these are specified explicitly.
 - 4.2.1. **Distribution Provider:** One or more of the following Facilities, systems and equipment

owned by the Distribution Provider for the protection or restoration of the BES:

4.2.1.1. Each UFLS or UVLS System that:

- 4.2.1.1.1.** is part of a Load shedding program that is subject to one or more requirements in a Railbelt Reliability Council Standard; and
- 4.2.1.1.2.** performs automatic Load shedding under a common control system owned by the Responsible Entity, without human operator initiation, that the loss, compromise, or misuse of could have adverse impact on the reliable operation of the BES.

4.2.1.2. Each RAS where the RAS is subject to one or more requirements in a Railbelt Reliability Council Standard.

4.2.1.3. Each Protection System (excluding UFLS and UVLS) that applies to Transmission where the Protection System is subject to one or more requirements in a Railbelt Reliability Council Standard.

4.2.1.4. Each Cranking Path and group of Elements meeting the initial switching requirements from a Blackstart Resource up to and including the first interconnection point of the starting station service of the next generation unit(s) to be started.

4.2.2. Responsible Entities listed in 4.1 other than Distribution Providers:

All BES Facilities.

4.2.3. Exemptions: The following are exempt from Standard **RRC-CIP-002-1**:

- 4.2.3.1.** Cyber Systems at Facilities regulated by the Canadian Nuclear Safety Commission.
- 4.2.3.2.** Cyber Assets associated with communication networks and data communication links between discrete Electronic Security Perimeters (ESP).
- 4.2.3.3.** Cyber Systems, associated with communication networks and data communication links, between Cyber Systems, providing confidentiality and integrity of an ESP that extends to one or more geographic locations.
- 4.2.3.4.** The systems, structures, and components that are regulated by the Nuclear Regulatory Commission under a cyber security plan pursuant to 10 C.F.R. Section 73.54.
- 4.2.3.5.** For Distribution Providers, the systems and equipment that are not included in section 4.2.1 above.
- 4.2.3.6.** Responsible Entities that identify that they have no BES Cyber Systems categorized as high impact or medium impact according to the CIP-002 identification and categorization processes.

4.3. “Applicable Systems”: Each table has an “Applicable Systems” column to define the scope of systems to which a specific Requirement Part applies.

5. Effective Dates: Shall become effective on the first day of the first calendar quarter that is twenty-four (24) months following adoption by the Approving Authority.

B. Requirements and Measures

- R1.** Each Responsible Entity shall implement one or more documented process(es) to manage configuration changes, individually or by group, that collectively include each of the applicable requirement parts in *RRC-CIP-010-1 Table R1 – Configuration Change Management*. [Violation Risk Factor: Medium] [Time Horizon: Operations Planning].
- M1.** Evidence must include each of the applicable documented processes that collectively include each of the applicable requirement parts in *RRC-CIP-010-1 Table R1 – Configuration Change Management* and additional evidence to demonstrate implementation as described in the Measures column of the table.

RRC-CIP-010-1 Table R1 – Configuration Change Management			
Part	Applicable Systems	Requirements	Measures
1.1	High impact BCS and their associated: 1. Electronic Access Control or Monitoring Systems (EACMS); 2. Physical Access Control Systems (PACS); and 3. Protected Cyber Asset (PCA) Medium impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	Authorize changes that affect Applicable Systems where those changes alter the behavior of one or more cyber security controls, excluding procedural and physical controls, serving one or more requirement parts in CIP-005 or CIP-007, as defined by the Responsible Entity.	Examples of evidence may include, but are not limited to, one or more documented process(es) that authorize changes that affect Applicable Systems where those changes alter the behavior of one or more cyber security controls, excluding procedural and physical controls, serving one or more requirement parts in CIP-005 or CIP-007, as defined by the Responsible Entity, such as: • Change records documenting the authorization. • Change records authorizing systems to automate changes to Applicable Systems. Examples of changes that may alter the behavior of one or more cyber security controls may include, but are not limited to: • Installation, removal, or update of operating system, firmware, software, or cyber security patches, including changes to VCA parent images from which Applicable Systems will be instantiated (CIP-007 R1.1, R2)

RRC-CIP-010-1 Table R1 – Configuration Change Management			
Part	Applicable Systems	Requirements	Measures
			• Configuration changes that affect routable protocol network accessibility (CIP-007 R1.1) • Configuration changes affecting the establishment of, or access control through, an ESP (CIP-005 R1, R2) • Configuration of malicious code prevention methods (CIP-007 R3) • Configuration of security event logging/alerting (CIP-007 R4) • Configuration changes to authentication methods (e.g., a password enforcement policy change, but not users changing their password) (CIP-007 R5) • Configuration changes to CPU/memory sharing of VCAs on SCI (CIP-007 R1.3)
1.2	High impact BCS	1.2.1 Prior to implementing any change from Part 1.1 in the production environment, except during a CIP Exceptional Circumstance, test the changes in a test environment that minimizes differences with the production environment or test the changes in a production environment where the test is performed in a manner that minimizes adverse effects, to ensure that required cyber security controls in CIP-005 and CIP-007 are not adversely affected; and 1.2.2 Document the results of the testing and, if a test environment was used, the	An example of evidence may include, but is not limited to, a list of cyber security controls tested along with successful test results and a list of differences between the production and test environments with descriptions of how any differences were accounted for, including the date of the test, or logs from systems that automatically remediate deviations in required cyber security controls in CIP-005 and CIP-007.

RRC-CIP-010-1 Table R1 – Configuration Change Management			
Part	Applicable Systems	Requirements	Measures
		differences between the test environment and the production environment, including a description of the measures used to account for any differences in operation between the test and production environments.	
1.3	High impact BCS and their associated: 1. EACMS; and 2. PACS Medium impact BCS and their associated: 1. EACMS; 2. PACS SCI supporting an Applicable System in this Part. Note: Implementation does not require the Responsible Entity to renegotiate or abrogate existing contracts (including amendments to master agreements and purchase orders). Additionally, the following issues are beyond the scope of Part 1.6: (1) the actual terms and conditions of a procurement contract; and (2) vendor performance and adherence to a contract.	Prior to the installation of operating systems, firmware, software, or software patches and when the method to do so is available to the Responsible Entity from the software source: 1.3.1 Verify the identity of the software source; and 1.3.2 Verify the integrity of the software obtained from the software source.	An example of evidence may include but is not limited to a change request record that demonstrates the verification of identity of the software source and integrity of the software was performed prior to installation or a process which documents the mechanisms in place that would automatically ensure the identity of the software source and integrity of the software.
1.4	High impact BCS and their associated: 1. EACMS; and 2. PACS Medium impact BCS and their associated: 1. EACMS; 2. PACS; and	As a part of the changes authorized per Part 1.1, verify that the behavior(s) of the altered cyber security controls were not adversely affected.	An example of evidence may include, but is not limited to: • System generated evidence of automated verification of required behaviors. • Records from a verification process showing that, as a part of the change

RRC-CIP-010-1 Table R1 – Configuration Change Management			
Part	Applicable Systems	Requirements	Measures
	3. PCA SCI supporting an Applicable System in this Part.		process, the required behavior(s) of the altered security controls remain effective, were corrected, or the change was reversed.

- R2.** Each Responsible Entity shall implement one or more documented process(es) to monitor configuration changes that collectively include each of the applicable requirement parts in *RRC-CIP-010-1 Table R2 – Configuration Monitoring*. [Violation Risk Factor: Medium].
- M2.** Evidence must include each of the applicable documented processes that collectively include each of the applicable requirement parts in *RRC-CIP-010-1 Table R2 – Configuration Monitoring* and additional evidence to demonstrate implementation as described in the Measures column of the table.

RRC-CIP-010-1 Table R2- Configuration Monitoring			
Part	Applicable Systems	Requirements	Measures
2.1	High impact BES Cyber Systems and their associated: 1. EACMS; and 2. PCA SCI supporting an Applicable System in this Part.	Methods to monitor, per system capability, at least once every 35 calendar days, for unauthorized changes that affect Applicable Systems, where those changes alter the behavior of one or more cyber security controls, excluding procedural and physical controls, serving one or more requirement parts in CIP-007, as defined by the Responsible Entity; that include at least one cyber security control for each of the following: 2.1.1 Configuration on each Applicable System that affects its routable protocol network accessibility; 2.1.2 Configuration of CPU or memory sharing of VCAs on SCI; 2.1.3 Installation, removal, and update of operating system, firmware, software, and cyber security patches. 2.1.4 Configuration of malicious code protection methods; 2.1.5 Configuration of security event logging or alerting;	An example of evidence may include, but is not limited to, documented methods to monitor at least once every 35 calendar days. Monitoring system configuration or procedural controls demonstrating monitoring of at least one cyber security control for 2.1.1 through 2.1.7. Examples of evidence may include, but are not limited to, reports generated from automated tools or manual reviews along with records of investigation for any unauthorized changes that were detected. Note: monitoring of VCA parent images from which Applicable Systems will be instantiated is an example of an automated control for 2.1.3.

RRC-CIP-010-1 Table R2- Configuration Monitoring			
Part	Applicable Systems	Requirements	Measures
		2.1.6 Configuration of authentication methods; and 2.1.7 Changes to the enabled or disabled status of accounts. Document and investigate detected unauthorized changes.	

- R3.** Each Responsible Entity shall implement one or more documented process(es) that collectively include each of the applicable requirement parts in *RRC-CIP-010-1 Table R3– Vulnerability Assessments*. [Violation Risk Factor: Medium].
- M3.** Evidence must include each of the applicable documented processes that collectively include each of the applicable requirement parts in *RRC-CIP-010-1 Table R3 – Vulnerability Assessments* and additional evidence to demonstrate implementation as described in the Measures column of the table.

RRC-CIP-010-1 Table R3- Vulnerability Assessments			
Part	Applicable Systems	Requirements	Measures
3.1	High impact BES Cyber Systems and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium impact BES Cyber Systems and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	At least once every 15 calendar months, conduct a paper or active vulnerability assessment.	Examples of evidence may include, but are not limited to: • A document listing the date of the assessment (performed at least once every 15 calendar months), the controls assessed for each BES Cyber System along with the method of assessment; or • A document listing the date of the assessment and the output of any tools used to perform the assessment
3.2	High impact BES Cyber Systems. SCI supporting an Applicable System in this Part.	At least once every 36 calendar months, per system capability: 3.2.1 Perform an active vulnerability assessment in a test environment that minimizes differences with the production environment, or perform an active vulnerability assessment in a production environment where the test is performed in a manner that minimizes adverse effects; and 3.2.2 Document the results of the testing and, if a test environment was used, the differences between the test environment	An example of evidence may include, but is not limited to, a document listing the date of the assessment (performed at least once every 36 calendar months), the output of the tools used to perform the assessment, and a list of differences between the production and test environments with descriptions of how any differences were accounted for in conducting the assessment.

RRC-CIP-010-1 Table R3- Vulnerability Assessments			
Part	Applicable Systems	Requirements	Measures
		and the production environment, including a description of the measures used to account for any differences in operation between the test and production environments.	
3.3	High impact BCS and their associated: 1. EACMS; and 2. PCA SCI supporting an Applicable System in this Part.	Prior to becoming a new Applicable System, perform an active vulnerability assessment of the new Applicable System, except for: • Like replacements or additions with a previously assessed configuration of an existing Applicable System; or • CIP Exceptional Circumstances.	An example of evidence may include, but is not limited to: • The output of tools used to perform the assessment; or • Reports from automated assessment and remediation mechanisms (remediation VLANs, quarantine systems, 802.1x mechanisms that assess and remediate, etc.) that documents the date of the assessment performed prior to becoming a new Applicable System.
3.4	High impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	Document the results of the assessments conducted according to Parts 3.1, 3.2, and 3.3 and the action plan to remediate or mitigate vulnerabilities identified in the assessments including the planned date of completing the action plan and the execution status of any remediation or mitigation action items.	Examples of evidence may include, but are not limited to: • Reports or logs from automated mechanisms that perform remediation of VCAs at instantiation; or • Documentation listing the results or the review or assessment, a list of action items, documented proposed dates of completion for the action plan, and records of the status of the action items (such as minutes of a status meeting, updates in a work order system, or a spreadsheet tracking the action items).

- R4.** Each Responsible Entity, for its high impact and medium impact BES Cyber Systems, associated PCA, and associated SCI, shall implement, except under CIP Exceptional Circumstances, one or more documented plan(s) for Transient Cyber Assets (TCA) and Removable Media that include the sections in Attachment 1. *[Violation Risk Factor: Medium] [Time Horizon: Long-term Planning and Operations Planning]*
- M4.** Evidence shall include each of the documented plan(s) for TCAs and Removable Media that collectively include each of the applicable sections in Attachment 1 and additional evidence to demonstrate implementation of plan(s) for TCA and Removable Media. Additional examples of evidence per section are located in Attachment 2. If a Responsible Entity does not use TCA(s) or Removable Media, examples of evidence include, but are not limited to, a statement, policy, or other document that states the Responsible Entity does not use TCA(s) or Removable Media.

C. Compliance

1. Compliance Monitoring Responsibility

1.1. Compliance Enforcement Authority:

The RRC is the entity with the authority to monitor and enforce compliance with mandatory and enforceable Railbelt Reliability Council Standards.

1.2. Evidence Retention:

The following evidence retention periods identify the period of time an entity is required to retain specific evidence to demonstrate compliance. For instances where the evidence retention period specified below is shorter than the time since the last audit, the RRC may ask an entity to provide other evidence to show that it was compliant for the full time period since the last audit.

The Responsible Entity shall keep data or evidence to show compliance as identified below unless directed by the RRC to retain specific evidence for a longer period of time as part of an investigation:

- Each Responsible Entity shall retain evidence of each requirement in this standard for three calendar years.
- If a Responsible Entity is found non-compliant, it shall keep information related to the non-compliance until mitigation is complete and approved or the time specified above, whichever is longer.
- The RRC shall keep the last audit records and all requested and submitted subsequent audit records.

1.3. Compliance Monitoring and Enforcement Program:

Compliance Monitoring and Enforcement Program refers to the identification of the processes that will be used to evaluate data or information for the purpose of assessing performance or outcomes with the associated Railbelt Reliability Council Standards.

Table of Compliance Elements

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-010-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
R1	Medium	N/A	The Responsible Entity's change management process(es) does not include one of the required items listed in 1.2.1 through 1.2.2. (Requirement 1.2); OR The Responsible Entity's change management process(es) does not include one of the required items listed in R 1.3.1 through 1.3.2. (R 1.3)	The Responsible Entity change management process(es) did not include authorization for changes as required in R 1.1. (R 1.1) OR The Responsible Entity's change management process(es) does not include the two required items listed in 1.2.1 through 1.2.2. (R 1.2); OR The Responsible Entity's change management process(es) does not include the two required items listed in 1.3.1 through 1.3.2. (R 1.3) OR The Responsible Entity's change management process(es) does not include verification, as required by Requirement 1.4. (R 1.4)	The Responsible Entity neither documented nor implemented any change management process(es) that include required items in R 1.1 through R 1.4. (Requirement R1)

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-010-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
R2	Medium	The Responsible Entity did not monitor within 35 calendar days, but less than 45 calendar days as required by R 2.1.	The Responsible Entity's documented and implemented configuration monitoring process(es) does not include two of the required R 2.1.1 through 2.1.7 for Applicable Systems as required in R 2.1. OR The Responsible Entity did not monitor within 45 calendar days, but less than 55 calendar days as required by R 2.1.	The Responsible Entity's documented and implemented configuration monitoring process(es) does not include four of the required R 2.1.1 through 2.1.7 for Applicable Systems as required in R 2.1. OR The Responsible Entity did not monitor within 55 calendar days, but less than 65 calendar days as required by R 2.1.	The Responsible Entity neither documented nor implemented a configuration monitoring process(es); or the process does not include six or more of the required R 2.1.1 through 2.1.7 for Applicable Systems as required in R 2.1. OR The Responsible Entity did not monitor within 65 calendar days or more as required by R 2.1. OR The Responsible Entity neither documented nor investigated detected unauthorized changes. (R 2.1)

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-010-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
R3	Medium	The Responsible Entity performed a vulnerability assessment more than 15 months, but less than 17 months, since the last assessment on one of its Applicable Systems. (R 3.1) OR The Responsible Entity performed an active vulnerability assessment more than 36 months, but less than 38 months, since the last active assessment on one of its Applicable Systems. (R 3.2)	The Responsible Entity performed a vulnerability assessment more than 17 months, but less than 19 months, since the last assessment on one of its Applicable Systems. (R 3.1) OR The Responsible Entity performed an active vulnerability assessment more than 38 months, but less than 40 months, since the last active assessment on one of its Applicable Systems. (R 3.2)	The Responsible Entity performed a vulnerability assessment more than 19 months, but less than 21 months, since the last assessment on one of its Applicable Systems. (R 3.1) OR The Responsible Entity performed an active vulnerability assessment more than 40 months, but less than 42 months, since the last active assessment on one of its Applicable Systems. (R 3.2)	The Responsible Entity did not implement any vulnerability assessment processes for one of its Applicable Systems. (Requirement R3) OR The Responsible Entity performed a vulnerability assessment more than 21 months since the last assessment on one of its applicable BES Cyber Systems. (R 3.1) OR The Responsible Entity performed an active vulnerability assessment more than 42 months since the last active assessment on one of its applicable BES Cyber Systems. (R 3.2) OR The Responsible Entity did not perform the active vulnerability assessment of a Cyber System prior to it becoming an Applicable Systems. (R 3.3)

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-010-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
					OR The Responsible Entity has implemented one or more documented vulnerability assessment processes for each of its Applicable Systems, but has not documented the results of the vulnerability assessments, the action plans to remediate or mitigate vulnerabilities identified in the assessments, the planned date of completion of the action plan, and the execution status of the mitigation plans. (R 3.4)
R4	Medium	The Responsible Entity did not manage its Transient Cyber Asset(s) according to Attachment 1, Section 1.1. (Requirement R4) OR The Responsible Entity did not document the Removable Media sections according to Attachment 1, Section 3. (Requirement R4)	The Responsible Entity did not implement the Removable Media sections according to Attachment 1, Section 3. (Requirement R4) OR The Responsible Entity did not document mitigation of software vulnerabilities, mitigation for the introduction of malicious code, or mitigation of the	The Responsible Entity did not authorize its TCA(s) according to Attachment 1, Section 1.2. (R4) OR The Responsible Entity did not implement mitigation of software vulnerabilities, mitigation for the introduction of malicious code, or mitigation of the risk of unauthorized use for	The Responsible Entity did not document or implement one or more plan(s) for TCAs and Removable Media according to Requirement R4. (Requirement R4)

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-010-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
		OR The Responsible Entity did not document authorization for TCA managed by the Responsible Entity according to Attachment 1, Section 1.2. (Requirement R4)	risk of unauthorized use for TCA managed by the Responsible Entity according to Attachment 1, Sections 1.3, 1.4, and 1.5. (Requirement R4) OR The Responsible Entity did not document mitigation of software vulnerabilities or mitigation for the introduction of malicious code for Transient Cyber Assets managed by a party other than the Responsible Entity according to Attachment 1, Sections 2.1, 2.2, and 2.3. (Requirement R4)	TCAs managed by the Responsible Entity according to Attachment 1, Sections 1.3, 1.4, and 1.5. (Requirement R4) OR The Responsible Entity did not implement mitigation of software vulnerabilities or mitigation for the introduction of malicious code for TCAs managed by a party other than the Responsible Entity according to Attachment 1, Sections 2.1, 2.2, and 2.3. (Requirement R4)	

D. Regional Variances

None.

E. Interpretations

None.

F. Associated Documents

None.

Version History

Version	Date	Action	Change Tracking

RRC-CIP-010-1 Attachment 1

Required Sections for Plans for Transient Cyber Assets and Removable Media

Responsible Entities shall include each of the sections provided below in their plan(s) for Transient Cyber Assets and Removable Media as required under Requirement R4.

Section 1. TCA(s) Managed by the Responsible Entity.

- 1.1 TCA Management: Responsible Entities shall manage TCA(s), individually or by group: (1) in an ongoing manner to ensure compliance with applicable requirements at all times, (2) in an on-demand manner applying the applicable requirements before connection, or (3) a combination of both (1) and (2) above.
- 1.2 TAC Authorization: For each individual or group of TCA(s), each Responsible Entity shall authorize:
 - 1.2.1 Users, either individually or by group or role;
 - 1.2.2 Locations, either individually or by group; and
 - 1.2.3 Uses, which shall be limited to what is necessary to perform business functions.
- 1.3 Software Vulnerability Mitigation: Use one or a combination of the following methods to achieve the objective of mitigating the risk of vulnerabilities posed by unpatched software on the TCA (per TCA capability):
 - Security patching, including manual or managed updates;
 - System hardening; or
 - Other method(s) to mitigate software vulnerabilities.
- 1.4 Introduction of Malicious Code Mitigation: Use one or a combination of the following methods to achieve the objective of mitigating the risk of introduction of malicious code (per TCA capability):
 - Antivirus software, including manual or managed updates of signatures or patterns;
 - Application whitelisting;
 - Live operating system and software executable only from read only media;
 - System hardening; or
 - Other method(s) to mitigate the introduction of malicious code.
- 1.5 Unauthorized Use Mitigation: Use one or a combination of the following methods to achieve the objective of mitigating the risk of unauthorized use of TCA(s):
 - Restrict physical access;
 - Full-disk encryption with authentication;
 - Multi-factor authentication; or
 - Other method(s) to mitigate the risk of unauthorized use.

Section 2. TCA(s) Managed by a Party Other than the Responsible Entity.

- 2.1 Software Vulnerabilities Mitigation: Use one or a combination of the following methods to achieve the objective of mitigating the risk of vulnerabilities posed by unpatched software on the TCA (per TCA capability):
 - Review of installed security patch(es);
 - Review of security patching process used by the party;
 - Review of other vulnerability mitigation performed by the party; or
 - Review of other method(s) to mitigate software vulnerabilities.

2.2 Introduction of malicious code mitigation: Use one or a combination of the following methods to achieve the objective of mitigating the risk of introduction of malicious code (per TCA capability):

- Review of antivirus update level;
- Review of antivirus update process used by the party;
- Review of application whitelisting used by the party;
- Review use of live operating system and software executable only from read only media;
- Review of system hardening used by the party; or
- Review of other method(s) to mitigate the risk of introduction of malicious code.

2.3 For any method used as specified in 2.1 and 2.2, Responsible Entities shall determine whether any additional mitigation actions are necessary and implement such actions prior to connecting the TCA.

Section 3. Removable Media

3.1 Removable Media Authorization: For each individual or group of Removable Media, each Responsible Entity shall authorize:

- 3.1.1 Users, either individually or by group or role; and
- 3.1.2 Locations, either individually or by group.

3.2 Malicious Code Mitigation: To achieve the objective of mitigating the threat of introducing malicious code, each Responsible Entity shall:

- 3.2.1 Use method(s) to detect malicious code on Removable Media prior to connecting ; and
- 3.2.2 Mitigate the threat of detected malicious code.

RRC-CIP-010-1 - Attachment 2

Examples of Evidence for Plans for Transient Cyber Assets and Removable Media

- Section 1.1: Examples of evidence for Section 1.1 may include, but are not limited to, the method(s) of management for the TCA(s). This can be included as part of the TCA(s), part of the documentation related to authorization of TCA(s) managed by the Responsible Entity or part of a security policy.
- Section 1.2: Examples of evidence for Section 1.2 may include, but are not limited to, documentation from asset management systems, human resource management systems, or forms or spreadsheets that show authorization of TCA(s) managed by the Responsible Entity. Alternatively, this can be documented in the overarching plan document.
- Section 1.3: Examples of evidence for Section 1.3 may include, but are not limited to, documentation of the method(s) used to mitigate the risk of software vulnerabilities posed by unpatched software such as security patch management implementation, the use of live operating system and software executable only from read only media, the use of controls that maintain the state of the operating system and software such that it is in a known state prior to execution, system hardening practices or other method(s) to mitigate the risk of software vulnerability posed by unpatched software. Evidence can be from change management systems, automated patch management solutions, procedures or processes associated with using live operating systems, methods to maintain the known good state of the OS and all software, or system hardening practices. If a TCA does not have the capability to use method(s) that mitigate the risk from unpatched software, evidence may include documentation by the vendor or Responsible Entity that identifies that the TCA does not have the capability.
- Section 1.4: Examples of evidence for Section 1.4 may include, but are not limited to, documentation of the method(s) used to mitigate the introduction of malicious code such as antivirus software and processes for managing signature or pattern updates, application whitelisting practices, processes to restrict communication, or other method(s) to mitigate the introduction of malicious code. If a Transient Cyber Asset does not have the capability to use method(s) that mitigate the introduction of malicious code, evidence may include documentation by the vendor or Responsible Entity that identifies that the TCA does not have the capability.
- Section 1.5: Examples of evidence for Section 1.5 may include, but are not limited to, documentation through policies or procedures of the method(s) to restrict physical access; method(s) of the full-disk encryption solution along with the authentication protocol; method(s) of the multi-factor authentication solution; or documentation of other method(s) to mitigate the risk of unauthorized use.
- Section 2.1: Examples of evidence for Section 2.1 may include, but are not limited to, documentation from change management systems, electronic mail or procedures that document a review of installed security patch(es); memoranda, electronic mail, policies or contracts from parties other than the Responsible Entity that identify the security patching process or vulnerability mitigation performed by the party other than the Responsible Entity; memoranda, electronic mail, policies or contracts from parties other than the Responsible Entity that document a review of the use of live operating system and software executable only from read only media; memoranda, electronic mail, policies, or contracts from parties other than the Responsible Entity that document a review of the use of controls that maintain the state of the operating system and software such that it is in a known state prior to execution; evidence from change management systems, electronic mail,

system documentation or contracts that identifies acceptance by the Responsible Entity that the practices of the party other than the Responsible Entity are acceptable; or documentation of other method(s) to mitigate software vulnerabilities for TCA(s) managed by a party other than the Responsible Entity. If a TCA does not have the capability to use method(s) that mitigate the risk from unpatched software, evidence may include documentation by the Responsible Entity or the party other than the Responsible Entity that identifies that the TCA does not have the capability.

Section 2.2: Examples of evidence for Section 2.2 may include, but are not limited to, documentation from change management systems, electronic mail or procedures that document a review of the installed antivirus update level; memoranda, electronic mail, system documentation, policies or contracts from the party other than the Responsible Entity that identify the antivirus update process, the use of application whitelisting, and system hardening by the party other than the Responsible Entity; evidence from change management systems, electronic mail or contracts that identifies the Responsible Entity's acceptance that the practices of the party other than the Responsible Entity are acceptable; or documentation of other method(s) to mitigate malicious code for TCA(s) managed by a party other than the Responsible Entity. If a TCA does not have the capability to use method(s) that mitigate the introduction of malicious code, evidence may include documentation by the Responsible Entity or the party other than the Responsible Entity that identifies that the TCA does not have the capability.

Section 2.3: Examples of evidence for Section 2.3 may include, but are not limited to, documentation from change management systems, electronic mail, or contracts that identifies a review to determine whether additional mitigations are necessary and that they have been implemented prior to connecting the TCA managed by a party other than the Responsible Entity.

Section 3.1: Examples of evidence for Section 3.1 may include, but are not limited to, documentation from asset management systems, human resource management systems, forms or spreadsheets that shows authorization of Removable Media. The documentation must identify Removable Media, individually or by group of Removable Media, along with the authorized users, either individually or by group or role, and the authorized locations, either individually or by group.

Section 3.2: Examples of evidence for Section 3.2 may include, but are not limited to, documented process(es) of the method(s) used to mitigate malicious code such as results of scan settings for Removable Media, or implementation of on-demand scanning. Documented process(es) for the method(s) used for mitigating the threat of detected malicious code on Removable Media, such as logs from the method(s) used to detect malicious code that show the results of scanning and that show mitigation of detected malicious code on Removable Media or documented confirmation by the entity that the Removable Media was deemed to be free of malicious code.

Balancing Authority	The responsible entity that integrates resource plans ahead of time, maintains Demand and resource balance within a Balancing Authority Area, and supports Interconnection frequency in real time.
BES Cyber Asset (BCA)	A Cyber Asset that if rendered unavailable, degraded, or misused would, within 15 minutes of its required operation, misoperation, or non operation, adversely impact one or more Facilities, systems, or equipment, which, if destroyed, degraded, or otherwise rendered unavailable when needed, would affect the reliable operation of the Bulk Electric System. Redundancy of affected Facilities, systems, and equipment shall not be considered when determining adverse impact. Each BES Cyber Asset is included in one or more BES Cyber Systems.
BES Cyber System (BCS)	One or more BES Cyber Assets logically grouped by a responsible entity to perform one or more reliability tasks for a functional entity.
BES Cyber System Information (BCSI)	Information about the BES Cyber System that could be used to gain unauthorized access or pose a security threat to the BES Cyber System. BES Cyber System Information does not include individual pieces of information that by themselves do not pose a threat or could not be used to allow unauthorized access to BES Cyber Systems, such as, but not limited to, device names, individual IP addresses without context, ESP names, or policy statements. Examples of BES Cyber System Information may include, but are not limited to, security procedures or security information about BES Cyber Systems, Physical Access Control Systems, and Electronic Access Control or Monitoring Systems that is not publicly available and could be used to allow unauthorized access or unauthorized distribution; collections of network addresses; and network topology of the BES Cyber System.
Blackstart Resource	A generating unit(s) and its associated set of equipment which has the ability to be started without support from the System or is designed to remain energized without connection to the remainder of the System, with the ability to energize a bus, meeting the Transmission Operator's restoration plan needs for Real and Reactive Power capability, frequency and voltage control, and that has been included in the Transmission Operator's restoration plan.
Bulk Electric System (BES)	Unless modified by the lists shown below, all Transmission Elements operated at 100 kV or higher and Real Power and Reactive Power resources connected at 100 kV or higher. This does not include facilities used in the local distribution of electric energy. Inclusions: • I1 - Transformers with the primary terminal and at least one secondary terminal operated at 100 kV or higher unless excluded by application of Exclusion E1 or E3. • I2 – Generating resource(s) including the generator terminals through the high-side of the

step-up transformer(s) connected at a voltage of 100 kV or above with:

- a) Gross individual nameplate rating greater than 20 MVA. Or,
- b) Gross plant/facility aggregate nameplate rating greater than 75 MVA.

- I3 - Blackstart Resources identified in the Transmission Operator's restoration plan.

- I4 - Dispersed power producing resources that aggregate to a total capacity greater than 75 MVA (gross nameplate rating), and that are connected through a system designed primarily for delivering such capacity to a common point of connection at a voltage of 100 kV or above. Thus, the facilities designated as BES are:

- a) The individual resources, and

The system designed primarily for delivering capacity from the point where those resources aggregate to greater than 75 MVA to a common point of connection at a voltage of 100 kV or above.

- I5 –Static or dynamic devices (excluding generators) dedicated to supplying or absorbing

Reactive Power that are connected at 100 kV or higher, or through a dedicated transformer with a high-side voltage of 100 kV or higher, or through a transformer that is designated in Inclusion I1 unless excluded by application of Exclusion E4

Exclusions:

- E1 - Radial systems: A group of contiguous transmission Elements that emanates from a single point of connection of 100 kV or higher and:

- a) Only serves Load. Or,
- b) Only includes generation resources, not identified in Inclusions I2, I3, or I4, with an aggregate capacity less than or equal to 75 MVA (gross nameplate rating). Or,
- c) Where the radial system serves Load and includes generation resources, not identified in Inclusions I2, I3 or I4, with an aggregate capacity of non- retail generation less than or equal to 75 MVA (gross nameplate rating).

Note 1 – A normally open switching device between radial systems, as depicted on prints or one-line diagrams for example, does not affect this exclusion.

Note 2 – The presence of a contiguous loop, operated at a voltage level of 50 kV or less, between configurations being considered as radial systems, does not affect this exclusion.

- E2 - A generating unit or multiple generating units on the customer's side of the retail meter that serve all or part of the retail Load with electric energy if: (i) the net capacity provided to the BES does not exceed 75 MVA, and (ii) standby, back-up, and maintenance power services are provided to the generating unit or multiple generating units or to the retail Load by a Balancing Authority, or provided pursuant to a binding obligation with a

Generator Owner or Generator Operator, or under terms approved by the applicable regulatory authority.

- E3 - Local networks (LN): A group of contiguous transmission Elements operated at less than 300 kV that distribute power to Load rather than transfer bulk power across the interconnected system. LN's emanate from multiple points of connection at 100 kV or higher to improve the level of service to retail customers and not to accommodate bulk power transfer

	across the interconnected system. The LN is characterized by all of the following: a) Limits on connected generation: The LN and its underlying Elements do not include generation resources identified in Inclusions I2, I3, or I4 and do not have an aggregate capacity of non-retail generation greater than 75 MVA (gross nameplate rating); b) Real Power flows only into the LN and the LN does not transfer energy originating outside the LN for delivery through the LN; and c) Not part of a Flowgate or transfer path: The LN does not contain any part of a permanent Flowgate in the Eastern Interconnection, a major transfer path within the Western Interconnection, or a comparable monitored Facility in the ERCOT or Quebec Interconnections, and is not a monitored Facility included in an Interconnection Reliability Operating Limit (IROL). • E4 – Reactive Power devices installed for the sole benefit of a retail customer(s). Note - Elements may be included or excluded on a case-by-case basis through b) the Rules of Procedure exception process.
CIP Exceptional Circumstance	A situation that involves or threatens to involve one or more of the following, or similar, conditions that impact safety or BES reliability: a risk of injury or death; a natural disaster; civil unrest; an imminent or existing hardware, software, or equipment failure; a Cyber Security Incident requiring emergency assistance; a response by emergency services; the enactment of a mutual assistance agreement; or an impediment of large scale workforce availability.
CIP Senior Manager	A single official with the authority to bind the registered entity to adhere to the requirements within the CIP Standards, CIP-002 through CIP-015.
Control Center	One or more facilities hosting operating personnel that monitor and control the Bulk Electric System (BES) in real-time to perform the reliability tasks, including their associated data centers, of: 1) a Reliability Coordinator, 2) a Balancing Authority, 3) a Transmission Operator for transmission Facilities at two or more locations, or 4) a Generator Operator for generation Facilities at two or more locations.
Cranking Path	A portion of the electric system that can be isolated and then energized to deliver electric power from a generation source to enable the startup of one or more other generating units.
Cyber Assets	Programmable electronic devices, including the hardware, software, and data in those devices.
Cyber Security Incident	A malicious act or suspicious event that: • For a high or medium impact BES Cyber System, compromises or attempts to compromise (1) an Electronic Security Perimeter, (2) a Physical Security Perimeter, or (3) an Electronic Access Control or Monitoring System; or Disrupts or attempts to disrupt the operation of a BES Cyber System

Distribution Provider	Provides and operates the “wires” between the transmission system and the end-use customer. For those end-use customers who are served at transmission voltages, the Transmission Owner also serves as the Distribution Provider. Thus, the Distribution Provider is not defined by a specific voltage, but rather as performing the distribution function at any voltage
Electronic Access Control or Monitoring Systems (EACMS)	Cyber Assets that perform electronic access control or electronic access monitoring of the Electronic Security Perimeter(s) or BES Cyber Systems. This includes Intermediate Systems.
Electronic Access Point	A Cyber Asset interface on an Electronic Security Perimeter that allows routable communication between Cyber Assets outside an Electronic Security Perimeter and Cyber Assets inside an Electronic Security Perimeter.
Electronic Security Perimeter	The logical border surrounding a network to which BES Cyber Systems are connected using a routable protocol.
Element	Any electrical device with terminals that may be connected to other electrical devices such as a generator, transformer, circuit breaker, bus section, or transmission line. An Element may be comprised of one or more components.
External Routable Connectivity	Programmable electronic devices, excluding Shared Cyber Infrastructure, including the hardware, software, and data in those devices. Application containers are considered software of Virtual Cyber Assets (VCAs) or Cyber Assets. VCAs are not considered software or data of Cyber Assets.
Facility	A set of electrical equipment that operates as a single Bulk Electric System Element (e.g., a line, a generator, a shunt compensator, transformer, etc.)
Interactive Remote Access	User-initiated access by a person employing a remote access client or other remote access technology using a routable protocol. Remote access originates from a Cyber Asset that is not an Intermediate System and not located within any of the Responsible Entity’s Electronic Security Perimeter(s) or at a defined Electronic Access Point (EAP). Remote access may be initiated from: 1) Cyber Assets used or owned by the Responsible Entity, 2) Cyber Assets used or owned by employees, and 3) Cyber Assets
Physical Access Control Systems	Cyber Assets that control, alert, or log access to the Physical Security Perimeter(s), exclusive of locally mounted hardware or devices at the Physical Security Perimeter such as motion sensors, electronic lock control mechanisms, and badge readers.
Physical Security Perimeter	The physical border surrounding locations in which BES Cyber Assets, BES Cyber Systems, or Electronic Access Control or Monitoring Systems reside, and for which access is controlled.

Protected Cyber Assets	One or more Cyber Assets connected using a routable protocol within or on an Electronic Security Perimeter that is not part of the highest impact BES Cyber System within the same Electronic Security Perimeter. The impact rating of Protected Cyber Assets is equal to the highest rated BES Cyber System in the same ESP.
Shared Cyber Infrastructure	One or more programmable electronic devices, including the software that shares the devices' resources, that: • Hosts one or more Virtual Cyber Assets (VCA) included in a BES Cyber Systems (BCS) or their associated Electronic Access Control or Monitoring Systems (EACMS) or Physical Access Control Systems (PACS); and hosts one or more VCAs that are not included in, or associated with, BCS of the same impact categorization; or • Provides storage resources required for system functionality of one or more Cyber Assets or VCAs included in a BCS or their associated EACMS or PACS; and also for one or more Cyber Assets or VCAs that are not included in, or associated with, BCS of the same impact categorization. SCI does not include the supported VCAs or Cyber Assets with which it shares its resources.
Remedial Action Scheme (RAS)	The following do not individually constitute a RAS: a) Protection Systems installed for the purpose of detecting Faults on BES Elements and isolating the faulted Elements b) Schemes for automatic underfrequency load shedding (UFLS) and automatic undervoltage load shedding (UVLS) comprised of only distributed relays c) Out-of-step tripping and power swing blocking d) Automatic reclosing schemes e) Schemes applied on an Element for non-Fault conditions, such as, but not limited to, generator loss-of-field, transformer top-oil temperature, overvoltage, or overload to protect the Element against damage by removing it from service f) Controllers that switch or regulate one or more of the following: series or shunt reactive devices, flexible alternating current transmission system (FACTS) devices, phase-shifting transformers, variable-frequency transformers, or tap-changing transformers; and, that are located at and monitor quantities solely at the same station as the Element being switched or regulated g) FACTS controllers that remotely switch static shunt reactive devices located at other stations to regulate the output of a single FACTS device h) Schemes or controllers that remotely switch shunt reactors and shunt capacitors for voltage regulation that would otherwise be manually switched i) Schemes that automatically de-energize a line for a non-Fault operation when one end of the line is open j) Schemes that provide anti-islanding protection (e.g., protect load from effects of being isolated with generation that may not be capable of maintaining acceptable frequency and voltage) k) Automatic sequences that proceed when manually initiated solely by a System Operator l) Modulation of HVdc or FACTS via supplementary controls, such as angle damping or frequency damping applied to damp local or inter-area oscillations m) oscillations

	n) Sub-synchronous resonance (SSR) protection schemes that directly detect sub-synchronous quantities (e.g., currents or torsional oscillations) o) Generator controls such as, but not limited to, automatic generation control (AGC), generation excitation [e.g. automatic voltage regulation (AVR) and power system stabilizers(PSS)], fast valving, and speed governing
Reportable Cyber Security Incident	A Cyber Security Incident that compromised or disrupted: - A BES Cyber System that performs one or more reliability tasks of a functional entity; - An Electronic Security Perimeter of a high or medium impact BES CyberSystem; or - An Electronic Access Control or Monitoring System of a high or medium impact BES Cyber System
Transient Cyber Asset	A Cyber Asset that is: 1. capable of transmitting or transferring executable code, 2. not included in a BES Cyber System, 3. not a Protected Cyber Asset (PCA) associated with high or medium impact BES Cyber Systems, and 4. directly connected (e.g., using Ethernet, serial, Universal Serial Bus, or wireless including near field or Bluetooth communication) for 30 consecutive calendar days or less to a: • BES Cyber Asset, • network within an Electronic Security Perimeter (ESP) containing high or medium impact BES Cyber Systems, or • PCA associated with high or medium impact BES Cyber Systems. Examples of Transient Cyber Assets include, but are not limited to, Cyber Assets used for data transfer, vulnerability assessment, maintenance, or troubleshooting purposes.
Transmission	An interconnected group of lines and associated equipment for the movement or transfer of electric energy between points of supply and points at which it is transformed for delivery to customers or is delivered to other electric systems.
Transmission Line	A system of structures, wires, insulators and associated hardware that carry electric energy from one point to another in an electric power system. Lines are operated at relatively high voltages varying from 69 kV up to 765 kV, and are capable of transmitting large quantities of electricity over long distances.
Transmission Planner	The entity that develops a long-term (generally one year and beyond) plan for the reliability (adequacy) of the interconnected bulk electric transmission systems within its portion of the Planning Authority area.
Transmission Operator	The entity responsible for the reliability of its “local” transmission system, and that operates or directs the operations of the transmission Facilities.

Transmission Owner	The entity that owns and maintains transmission Facilities.
Undervoltage Load Shedding Program	An automatic load shedding program, consisting of distributed relays and controls, used to mitigate undervoltage conditions impacting the Bulk Electric System (BES), leading to voltage instability, voltage collapse, or Cascading. Centrally controlled undervoltage-based load shedding is not included.